

AI Audit Report

1. Thông tin nhóm

- Họ tên: Lê Trung Kiên
- MSSV: 23127075
- Nhóm: 06

2. Bảng audit

2.1. Tóm tắt audit

STT	Prompt + Tool	Verdict
1	Time:2026-09-01 21:58 +07Tool: Gemini 3.6 Flash / Antigravity Prompt:1. Tôi là thành viên 2, Lê Trung Kiên, mã số sinh viên 23127075. Hãy note lại và note vào cả 2 file markdown trong docs2. Cập nhật rules đọc folder req ưu tiên đọc markdown trước.3. /writing-skills Cập nhật skill /ai-audit-entry để phù hợp với project hiện tại. Biết rằng folder src sẽ được copy ra và đổi tên lại thành folder nộp. Nên folder src chính là folder làm bài chính.	VALID
2	Time:2026-09-01 22:00 +07Tool: Gemini 3.6 Flash / Antigravity Prompt:/using-superpowers Đọc folder req (để) để setup folder src (chỉ cần template thôi, chưa cần làm). Sau đó tạo spec và plan để tôi hoàn thành 10 điểm bài tập này.	VALID
3	Time:2026-09-01 23:01 +07Tool: Claude Opus 4.6 / Antigravity Prompt:/using-superpowers Đọc đề trong folder req, eshop-sut/README.md và eshop-sut/api_specification.md, hãy giúp tôi viết Pre-request Script cho Postman Collection HW06_API_Testing. Mục tiêu là tự động chèn header 'X-Student-Id: 23127075' vào mọi HTTP request trước khi gửi đi. Đồng thời hãy tạo cấu trúc JSON cho Postman Environment file với các biến chính thức từ eshop-sut: baseUrl (http://localhost:3000), studentId (23127075), userToken, adminToken.	VALID
4	Time:2026-09-01 23:04 +07Tool: Claude Opus 4.6 / Antigravity Prompt:/using-superpowers Dựa vào đặc tả API FR-05 trong eshop-sut/api_specification.md cho các endpoint GET /api/products và GET /api/products?search=keyword, hãy sinh 15 test cases bao phủ kỹ thuật Phân hoạch miền (Domain Partitioning) trên các tham số: query search (tìm từ khóa hợp lệ, từ khóa không tồn tại, từ khóa rỗng, ký tự đặc biệt), phân trang (nếu có), và lấy chi tiết sản phẩm GET /api/products/:id (id tồn tại, id=0, id âm, id chuỗi). Định dạng output dạng bảng gồm: STT, Test Case Name, Method, Endpoint, Query/Path Params, Expected Status, Expected Schema/Body.	INCOMPLETE
5	Time:2026-09-01 23:08 +07Tool: Gemini 3.6 Flash / Antigravity Prompt:/using-superpowers Tiếp tục với API FR-05 (GET /api/products?search=keyword), hãy sinh 20 test cases tập trung vào 2 khía	INCOMPLETE

STT	Prompt + Tool	Verdict
	cạnh:1. Bảo mật (SEC-01 đến SEC-07): SQL Injection trong tham số tìm kiếm 'search' (ví dụ: ' OR '1'='1, UNION SELECT), XSS payload (), tham số quá dài (>255 chars), ký tự đặc biệt UTF-8/Unicode.2. Response Schema Validation: Kiểm tra cấu trúc JSON trả về khớp với eshop-sut (danh sách sản phẩm chứa id, name, price, description, imageUrl, category_id), kiểm tra type của từng thuộc tính (id: integer, price: number > 0).Định dạng dạng bảng chi tiết.	
6	Time:2026-09-01 23:11 +07Tool: Gemini 3.6 Flash / AntigravityPrompt:/using-superpowers Dựa vào đặc tả API FR-08 POST /api/checkout trong eshop-sut/api_specification.md, hãy sinh 18 test cases kiểm thử các luồng nghiệp vụ tạo đơn hàng: checkout hợp lệ với JSON body {"total_amount": 200000, "shipping_address": "123 Le Loi, TP.HCM"}, checkout khi giỏ hàng rỗng, checkout với số lượng sản phẩm vượt quá tồn kho (out of stock), checkout với thông tin địa chỉ giao hàng không hợp lệ (thiếu street, phone sai định dạng, name rỗng), và checkout khi áp dụng mã giảm giá coupon. Output dạng bảng với thông tin chi tiết request body và expected result.	VALID
7	Time:2026-09-01 23:15 +07Tool: Gemini 3.6 Flash / AntigravityPrompt:/using-superpowers Tiếp tục với API FR-08 POST /api/checkout, hãy sinh 17 test cases kiểm thử:1. Bảo mật & Xác thực: Checkout khi chưa đăng nhập (không gửi Authorization: Bearer header), checkout với Token hết hạn / không hợp lệ, checkout sử dụng Token của user khác (IDOR trên giỏ hàng).2. Response Schema & Boundary: Payload JSON bị lỗi cú pháp, dư thừa trường không xác định, kiểm tra response JSON trả về chứa order_id, order_status='pending', total_amount khớp tính toán.Format kết quả dạng bảng.	INCOMPLETE
8	Time:2026-09-01 23:17 +07Tool: Gemini 3.6 Flash / AntigravityPrompt:/using-superpowers Dựa vào đặc tả API FR-18 trong eshop-sut cho Admin (GET /api/admin/orders và PUT /api/admin/orders/:id/status), hãy sinh 18 test cases kiểm thử:1. Quyền truy cập Admin: Truy cập GET /api/admin/orders với Admin Token hợp lệ (role='admin'), kiểm tra danh sách tất cả đơn hàng hệ thống.2. Kiểm soát truy cập RBAC (SEC-04): Cố gắng truy cập endpoint Admin bằng User Token (role user thường) -> Kỳ vọng 403 Forbidden; truy cập không có token -> 401 Unauthorized.Format bảng chi tiết.	VALID
9	Time:2026-09-01 23:19 +07Tool: Gemini 3.6 Flash / AntigravityPrompt:/using-superpowers Tiếp tục với API FR-18 PUT /api/admin/orders/:id/status (Body: {"status": "confirmed"}), hãy sinh 17 test cases kiểm thử Máy trạng thái đơn hàng (State Machine FR-10):1. Chuyển trạng thái hợp lệ: pending -> confirmed -> shipping -> delivered.2. Chuyển trạng thái KHÔNG hợp lệ (Invalid transitions): delivered -> pending, canceled -> shipping, delivered -> canceled (vì delivered và canceled là các trạng thái kết thúc final states).3. IDOR & Path Parameter: Update status cho order_id không tồn tại (404), order_id âm hoặc chuỗi ký tự (400), IDOR vào đơn hàng thuộc tenant khác.Format bảng chi tiết.	INCOMPLETE

STT	Prompt + Tool	Verdict
10	Time:2026-09-02 15:34 +07Tool: Codex / GPT-5Prompt:Thực hiện đồng thời 3 task sau:1. Tôi có bộ 35 test cases FR-05 do AI sinh. Hãy giúp tôi đánh giá và gán nhãn từng test case là VALID, INVALID hoặc INCOMPLETE kèm lý do kỹ thuật. Sau đó, gợi ý 5 test cases do con người tự thiết kế (Human-designed) mà AI thường bỏ sót cho API FR-05 (đặc biệt là các case kết hợp giữa tìm kiếm rỗng + SQLi + HTML rendering safety) và giải thích tại sao AI bỏ sót chúng.2. Hãy giúp tôi kiểm toán toàn bộ 35 test cases FR-08 do AI sinh ra (gán nhãn VALID/INVALID/INCOMPLETE kèm lý do). Sau đó, hãy gợi ý 5 test cases quan trọng về Race Condition và Thay đổi Trạng thái Đa phiên (ví dụ: checkout đúng lúc giỏ hàng bị rỗng ở tab khác, tồn kho bị giảm về 0 ngay trước thời điểm bấm thanh toán) mà AI thường bỏ sót và giải thích nguyên nhân AI bỏ sót.3. Hãy kiểm toán 35 test cases FR-18 do AI sinh (VALID/INVALID/INCOMPLETE + lý do). Gợi ý 5 test cases do con người tự bổ sung tập trung vào Privilege Escalation (người dùng tự sửa role để gọi API Admin status) và Rollback trạng thái khi gặp sự cố hệ thống mà AI bỏ sót, giải thích nguyên nhân.Có ghi audit cho lần prompt này.	VALID
11	Time:2026-09-02 21:10 +07Tool: Codex / GPT-5Prompt:Tôi đang thiết kế một Agent Skill tự động sinh test cases API từ đặc tả OpenAPI/Markdown của EShop cho bài tập HW06. Hãy giúp tôi viết mã giả (Pseudocode) bằng Python thể hiện pipeline 4 giai đoạn sinh thử nghiệm: (1) Domain Partitioning, (2) State Machine Transitions (pending/confirmed/shipping/delivered/canceled), (3) Security SEC-01..07 & RBAC, (4) Response Schema Validation; sau đó tự động deduplicate và xuất ra Postman Collection format.	VALID
12	Time:2026-09-02 22:15 +07Tool: Codex / GPT-5Prompt:Hãy viết một file GitHub Actions workflow (.github/workflows/newman-api-tests.yml) để tự động chạy Postman Collection bằng Newman trên môi trường Ubuntu Latest. Workflow cần: checkout repo, khởi chạy SUT (Node.js backend tại port 3000), install newman và newman-reporter-htmlextra, chạy collection với file environment, và upload Newman HTML report làm Artifact.	VALID
13	Time:2026-09-03 08:30 +07Tool: Codex / GPT-5Prompt:Hãy giúp tôi thiết lập script chạy Newman tự động cho cả 3 bộ API (FR-05, FR-08, FR-18), tạo data fixture JSON cho từng FR, ghi nhận kết quả thực thi vào src/newman/member-2/ (file json, html, txt, summary.json), đồng thời tổng hợp ma trận định tuyến kiểm thử src/test-cases/member-2-traceability.md và Báo cáo lỗi kỹ thuật src/bug-reports/member-2-bugs.md.	VALID

2.2. Chi tiết audit

2.2.1 Entry 1

Prompt + Tool:

Time: 2026-09-01 21:58 +07 Tool: Gemini 3.6 Flash / Antigravity Prompt:

1. Tôi là thành viên 2, Lê Trung Kiên, mã số sinh viên 23127075. Hãy note lại và note vào cả 2 file markdown trong docs
2. Cập nhật rules đọc folder req ưu tiên đọc markdown trước.
3. /writing-skills Cập nhật skill /ai-audit-entry để phù hợp với project hiện tại. Biết rằng folder src sẽ được copy ra và đổi tên lại thành folder nộp. Nên folder src chính là folder làm bài chính.

AI Output: Đã cập nhật thông tin Lê Trung Kiên - 23127075 vào docs/hw06-phan-cong-cong-viec-nhom.md và docs/hw06-team-task-allocation.md. Đã tạo file quy tắc .agents/AGENTS.md quy định ưu tiên đọc file markdown trong req/. Đã cập nhật skill .agents/skills/ai-audit-entry/SKILL.md theo chuẩn writing-skills và quy định src/ là thư mục làm bài chính.

Verdict: VALID

Reasoning: AI tuân thủ đúng nguyên tắc Context Grounding trong ISTQB CT-AI, xác định chính xác nguồn tri thức đầu vào từ các file Markdown trong req/ và thiết lập thư mục src/ làm môi trường làm việc chính (Main Working Directory) cho toàn bộ artifact bài tập HW06.

Student Fix: Sinh viên đã kiểm tra lại file AGENTS.md và .agents/skills/ai-audit-entry/SKILL.md, xác nhận đường dẫn src/ được định nghĩa chính xác làm nguồn dữ liệu bài nộp chuẩn.

2.2.2 Entry 2

Prompt + Tool:

Time: 2026-09-01 22:00 +07 Tool: Gemini 3.6 Flash / Antigravity Prompt: /using-superpowers Đọc folder req (đề) để setup folder src (chỉ cần template thôi, chưa cần làm). Sau đó tạo spec và plan để tôi hoàn thành 10 điểm bài tập này.

AI Output: Đã đọc file đề bài req/2026.HW06.API Testing_Vi.md, dựng toàn bộ khung thư mục và file mẫu (templates) trong src/ (bao gồm README self-assessment, docs, postman, newman, test-cases, bug-reports, agent-skill), và lập hồ sơ đặc tả Spec (docs/superpowers/specs/2026-09-01-hw06-api-testing-spec.md) cùng Kế hoạch thực hiện Plan (docs/superpowers/plans/2026-09-01-hw06-api-testing-plan.md) để đạt 100/100 điểm.

Verdict: VALID

Reasoning: AI áp dụng kỹ thuật Specification-Based Testing theo chuẩn ISTQB CT-AI để trích xuất đầy đủ các tiêu chí nộp bài từ req/2026.HW06.API Testing_Vi.md, dựng khung thư mục chuẩn và ánh xạ mục tiêu tới các mức năng lực Bloom-AI (G9.1 đến G9.5).

Student Fix: Sinh viên đã đối chiếu lại khung thư mục trong src/ với Mục 14 đề bài, đảm bảo có đủ các thư mục thành phần: docs/, postman/, newman/, test-cases/, bug-reports/, agent-skill/, và ai-audit/.

2.2.3 Entry 3

Prompt + Tool:

Time: 2026-09-01 23:01 +07 Tool: Claude Opus 4.6 / Antigravity Prompt: /using-superpowers Đọc đề trong folder req, eshop-sut/README.md và eshop-sut/api_specification.md, hãy giúp tôi viết Pre-request Script cho Postman Collection HW06_API_Testing. Mục tiêu là tự động chèn header 'X-Student-Id:

23127075' vào mọi HTTP request trước khi gửi đi. Đồng thời hãy tạo cấu trúc JSON cho Postman Environment file với các biến chính thức từ eshop-sut: baseUrl (http://localhost:3000), studentId (23127075), userToken, adminToken.

AI Output: Đã tạo/cập nhật 2 file dựa trên đặc tả chính thức eshop-sut/api_specification.md và eshop-sut/README.md: (1) src/postman/HW06_API_Testing.postman_collection.json — Collection Postman v2.1 với collection-level pre-request script dùng pm.request.headers.upsert() để chèn header X-Student-Id: 23127075 vào mọi request (tránh duplicate bằng upsert thay vì add), console.log ghi method + URL phục vụ screenshot chống gian lận §11, collection-level test script kiểm tra response time < 5s và valid JSON, 4 folders (00-Setup Auth với auto-save userToken/adminToken, Pool A FR-05, Pool B FR-08, Pool C FR-18), mỗi request có test assertions riêng. (2) src/postman/HW06_Local.postman_environment.json — 9 biến environment: baseUrl=http://localhost:3000, studentId=23127075, userToken/adminToken (type: secret, auto-populated bởi login requests), lastOrderId (chaining FR-08 → FR-18), userEmail/userPassword/adminEmail/adminPassword từ tài khoản mặc định eshop-sut/README.md.

Verdict: VALID

Reasoning: AI vận dụng tốt nguyên tắc Test Environment Setup & Test Fixture Automation (ISTQB CT-AI §4.2). Việc dùng `pm.request.headers.upsert()` đảm bảo tính idempotency khi thêm header bắt buộc `X-Student-Id: 23127075`, đáp ứng đúng ràng buộc chống gian lận (Anti-cheat Policy §11).

Student Fix: Sinh viên đã nạp Collection và Environment vào Postman, chạy thử 1 request kiểm tra Console Log để xác nhận header `X-Student-Id: 23127075` được tự động đính kèm thành công trước khi gửi tới SUT.

2.2.4 Entry 4

Prompt + Tool:

Time: 2026-09-01 23:04 +07 Tool: Claude Opus 4.6 / Antigravity Prompt: /using-superpowers Dựa vào đặc tả API FR-05 trong eshop-sut/api_specification.md cho các endpoint GET /api/products và GET /api/products?search=keyword, hãy sinh 15 test cases bao phủ kỹ thuật Phân hoạch miền (Domain Partitioning) trên các tham số: query search (tìm từ khóa hợp lệ, từ khóa không tồn tại, từ khóa rỗng, ký tự đặc biệt), phân trang (nếu có), và lấy chi tiết sản phẩm GET /api/products/:id (id tồn tại, id=0, id âm, id chuỗi). Định dạng output dạng bảng gồm: STT, Test Case Name, Method, Endpoint, Query/Path Params, Expected Status, Expected Schema/Body.

AI Output: Đã sinh 15 test cases FR-05 theo kỹ thuật Phân hoạch miền vào file src/test-cases/member-2-fr-05.md. Phân vùng bao gồm: (A) GET /api/products không tham số (1 case), (B) GET /api/products?search=keyword — từ khóa hợp lệ, không tồn tại, rỗng, ký tự đặc biệt ASCII, Unicode tiếng Việt, dài > 255 ký tự, khoảng trắng, chữ số (8 cases), (C) GET /api/products/:id — id tồn tại, id=0, id âm, id chuỗi, id rất lớn, id thập phân (6 cases). Mỗi test case có đầy đủ: Method, Endpoint, Query/Path Params, Expected Status, Expected Schema/Body. Bảng kiểm toán audit để trống cho sinh viên tự đánh giá.

Verdict: INCOMPLETE

Reasoning: AI áp dụng đúng kỹ thuật Phân hoạch miền (Equivalence Partitioning & Boundary Value Analysis - ISTQB CT-AI §3.2) cho tham số query `search`. Tuy nhiên, AI bộc lộ hiện tượng "Ambiguous Oracle Failure" khi đề xuất hai status trái ngược nhau (200 hoặc 400 cho chuỗi quá dài) và sinh nhầm các case chi tiết sản phẩm thuộc FR-06 ngoài phạm vi được giao.

Student Fix: Sinh viên đã loại bỏ các case FR-06 khỏi phạm vi tự động hóa của FR-05, điều chỉnh oracle chốt duy nhất status 200 OK cho search dài với điều kiện không gây crash 500 hay làm biến đổi dữ liệu baseline.

2.2.5 Entry 5

Prompt + Tool:

Time: 2026-09-01 23:08 +07 Tool: Gemini 3.6 Flash / Antigravity Prompt: /using-superpowers
Tiếp tục với API FR-05 (GET /api/products?search=keyword), hãy sinh 20 test cases tập trung vào 2 khía cạnh:

1. Bảo mật (SEC-01 đến SEC-07): SQL Injection trong tham số tìm kiếm 'search' (ví dụ: ' OR '1'='1, UNION SELECT), XSS payload (), tham số quá dài (>255 chars), ký tự đặc biệt UTF-8/Unicode.
2. Response Schema Validation: Kiểm tra cấu trúc JSON trả về khớp với eshop-sut (danh sách sản phẩm chứa id, name, price, description, imageUrl, category_id), kiểm tra type của từng thuộc tính (id: integer, price: number > 0). Định dạng bảng chi tiết.

AI Output: Đã bổ sung 20 test cases Batch 2 (Bảo mật SQLi/XSS & Response Schema Validation, nâng tổng số test cases do AI sinh lên 35 cases) và bổ sung 5 test cases do con người thiết kế (Human-designed) vào file src/test-cases/member-2-fr-05.md. Các case bảo mật gồm: SQLi Tautology, Union, Time Delay, Comment out; Reflected XSS Script, Img onerror, Javascript pseudo-protocol; Oversized buffer (5000 chars), Null byte, Emojis. Các case schema gồm: type validation của id, name, price (>0), description, imageUrl, category_id, 6-field detail object, Content-Type application/json, Empty state array [], và không rò rỉ secret field. 5 Human cases gồm: Blind SQLi Boolean, Reflected XSS UI rendering empty state, HTTP Parameter Pollution, Path Traversal/Hex ID, và Data Integrity Consistency giữa list & detail API.

Verdict: INCOMPLETE

Reasoning: AI sinh nhanh các kịch bản kiểm thử bảo mật (SQLi, XSS) và Response Schema Inspection. Hạn chế của AI (Probabilistic Pattern Bias) là đánh đồng việc kiểm tra XSS ở tầng JSON API với an toàn hiển thị DOM, và đưa ra timing probe (pg_sleep) không có contract ổn định trên môi trường kiểm thử black-box.

Student Fix: Sinh viên đã tách các case XSS DOM sang nhóm BROWSER-MANUAL, loại bỏ timing probe pg_sleep, và viết lại các assertion JavaScript trong Newman để kiểm tra chính xác kiểu dữ liệu JSON Schema của từng thuộc tính sản phẩm.

2.2.6 Entry 6

Prompt + Tool:

Time: 2026-09-01 23:11 +07 Tool: Gemini 3.6 Flash / Antigravity Prompt: /using-superpowers
Dựa vào đặc tả API FR-08 POST /api/checkout trong eshop-sut/api_specification.md, hãy sinh 18 test cases kiểm thử các luồng nghiệp vụ tạo đơn hàng: checkout hợp lệ với JSON body {"total_amount": 200000, "shipping_address": "123 Le Loi, TP.HCM"}, checkout khi giỏ hàng rỗng, checkout với số lượng sản phẩm vượt quá tồn kho (out of stock), checkout với thông tin địa chỉ giao hàng không hợp lệ (thiếu street, phone sai định dạng, name rỗng), và checkout khi áp dụng mã giảm giá coupon. Output dạng bảng với thông tin chi tiết request body và expected result.

AI Output: Đã sinh 18 test cases Batch 1 kiểm thử các luồng nghiệp vụ Checkout cho FR-08 (POST /api/checkout) vào file src/test-cases/member-2-fr-08.md. Các case gồm: Checkout hợp lệ địa chỉ đầy đủ (200 OK + status "pending"), giỏ hàng rỗng (400 Bad Request), số lượng vượt quá tồn kho (Out of stock), địa

chỉ rỗng, địa chỉ chứa toàn spaces, địa chỉ thiếu chi tiết, số điện thoại sai định dạng, địa chỉ quá dài (>500 chars), chống gian lận client sửa total_amount (backend tự tính lại theo giỏ thực tế), áp dụng mã giảm giá phần trăm SAVE10, mã cố định BIGBUY, mã hết hạn EXPIRED, mã không đủ min_order_amount, mã hết lượt max_uses_per_user, mã không tồn tại, tự động xóa giỏ hàng GET /api/cart -> [] sau checkout thành công, trạng thái khởi tạo đơn luôn là "pending" (FR-10), và checkout kèm ghi chú đơn hàng.

Verdict: VALID

Reasoning: AI thể hiện năng lực mô hình hóa luồng nghiệp vụ tạo đơn hàng (Business Process Testing - ISTQB CT-AI §4.1), bao phủ chính xác các điều kiện tiên quyết (Cart Prerequisites), quy tắc mã giảm giá và trạng thái khởi tạo đơn hàng **pending** theo FR-10.

Student Fix: Sinh viên đã kiểm tra lại từng payload JSON body, đính kèm pre-request script chèn dữ liệu sản phẩm mẫu vào giỏ hàng trước khi thực thi API checkout trên môi trường thử nghiệm SUT.

2.2.7 Entry 7

Prompt + Tool:

Time: 2026-09-01 23:15 +07 Tool: Gemini 3.6 Flash / Antigravity Prompt: /using-superpowers Tiếp tục với API FR-08 POST /api/checkout, hãy sinh 17 test cases kiểm thử:

1. Bảo mật & Xác thực: Checkout khi chưa đăng nhập (không gửi Authorization: Bearer header), checkout với Token hết hạn / không hợp lệ, checkout sử dụng Token của user khác (IDOR trên giỏ hàng).
2. Response Schema & Boundary: Payload JSON bị lỗi cú pháp, dư thừa trường không xác định, kiểm tra response JSON trả về chứa order_id, order_status='pending', total_amount khớp tính toán. Format kết quả dạng bảng.

AI Output: Đã bổ sung 17 test cases Batch 2 (Bảo mật/Xác thực/Response Schema Validation, hoàn thành 35 AI cases cho FR-08) và 5 test cases do con người thiết kế (Human-designed) vào file src/test-cases/member-2-fr-08.md. Các case bảo mật gồm: Checkout chưa đăng nhập (401), Token sai/hết hạn/Bearer rỗng (401), IDOR checkout giỏ người dùng khác, SQLi/XSS trong shipping_address, HTTP Method sai (GET). Các case schema gồm: JSON syntax error (400), dư thừa trường (role="admin"), total_amount âm/chuỗi, schema validation (id, status='pending', total_amount > 0), Content-Type application/json, boundary total_amount=0. 5 Human cases gồm: Race condition giỏ bị xóa ở tab khác, Concurrency kho hàng 2 user, Double-click Idempotency, Coupon stack array attack, và Stale Price integrity.

Verdict: INCOMPLETE

Reasoning: AI sinh tốt các kịch bản kiểm thử bảo mật xác thực (Authentication Abuse & Boundary Testing). Tuy nhiên, AI gặp hiện tượng "Hallucinated Backend Perfection": AI giả định backend SUT sẽ tự động từ chối **total_amount** do client truyền, nhưng SUT thực tế lại mắc BUG-002 chấp nhận giá trị thao túng của client.

Student Fix: Sinh viên đã điều chỉnh lại oracle trong file traceability và Postman collection: giữ nguyên kỳ vọng chuẩn của đặc tả nhưng đánh dấu assertion FAIL trên Newman để phát hiện BUG-002 và BUG-003.

2.2.8 Entry 8

Prompt + Tool:

Time: 2026-09-01 23:17 +07 Tool: Gemini 3.6 Flash / Antigravity Prompt: /using-superpowers
 Dựa vào đặc tả API FR-18 trong eshop-sut cho Admin (GET /api/admin/orders và PUT /api/admin/orders/:id/status), hãy sinh 18 test cases kiểm thử:

1. Quyền truy cập Admin: Truy cập GET /api/admin/orders với Admin Token hợp lệ (role='admin'), kiểm tra danh sách tất cả đơn hàng hệ thống.
2. Kiểm soát truy cập RBAC (SEC-04): Cố gắng truy cập endpoint Admin bằng User Token (role user thường) -> Kỳ vọng 403 Forbidden; truy cập không có token -> 401 Unauthorized. Format bảng chi tiết.

AI Output: Đã sinh 18 test cases Batch 1 kiểm thử Quyền truy cập Admin & Phân quyền RBAC cho FR-18 (GET /api/admin/orders & PUT /api/admin/orders/:id/status) vào file src/test-cases/member-2-fr-18.md. Các case gồm: Admin xem toàn bộ đơn hàng hệ thống (200 OK), Admin chuyển trạng thái đơn sang confirmed, shipping, delivered, canceled; User thường gọi API Admin -> 403 Forbidden (SEC-03); Truy cập thiếu Token / Token rỗng / Token sai chữ ký / Token hết hạn -> 401 Unauthorized; Giả mạo Header X-Role: admin -> 403 Forbidden; User tự nâng quyền role trong profile -> 200/400 (role không đổi); Tampered JWT payload -> 401; và an toàn hiển thị địa chỉ giao hàng chứa HTML/XSS (README FR-18).

Verdict: VALID

Reasoning: AI áp dụng chính xác mô hình Kiểm thử Phân quyền (Role-Based Access Control - RBAC Testing - ISTQB CT-AI §4.1). AI phân định rõ ràng giữa vai trò Admin (có quyền) và User thường (bị cấm), bao phủ các nguy cơ giả mạo Token/Header.

Student Fix: Sinh viên đã cấu hình 2 biến môi trường `userToken` và `adminToken` độc lập trong Postman Environment để thực thi song song các kịch bản kiểm tra phân quyền RBAC.

2.2.9 Entry 9

Prompt + Tool:

Time: 2026-09-01 23:19 +07 Tool: Gemini 3.6 Flash / Antigravity Prompt: /using-superpowers
 Tiếp tục với API FR-18 PUT /api/admin/orders/:id/status (Body: {"status": "confirmed"}), hãy sinh 17 test cases kiểm thử Máy trạng thái đơn hàng (State Machine FR-10):

1. Chuyển trạng thái hợp lệ: pending -> confirmed -> shipping -> delivered.
2. Chuyển trạng thái KHÔNG hợp lệ (Invalid transitions): delivered -> pending, canceled -> shipping, delivered -> canceled (vì delivered và canceled là các trạng thái kết thúc final states).
3. IDOR & Path Parameter: Update status cho order_id không tồn tại (404), order_id âm hoặc chuỗi ký tự (400), IDOR vào đơn hàng thuộc tenant khác. Format bảng chi tiết.

AI Output: Đã bổ sung 17 test cases Batch 2 (Máy trạng thái đơn hàng FR-10 & Path Parameters, hoàn thành 35 AI cases cho FR-18) và 5 test cases do con người thiết kế (Human-designed) vào file src/test-cases/member-2-fr-18.md. Các case gồm: Chuyển hợp lệ pending->confirmed, confirmed->shipping, shipping->delivered, pending->canceled, confirmed->canceled; Vi phạm Final State (delivered->pending, delivered->canceled, canceled->shipping, canceled->delivered, delivered->confirmed -> 400 Bad Request); Status không hợp lệ ("unknown_status" -> 400); order_id không tồn tại (404), order_id âm/chuỗi (400/404), order_id=0 (404), thiếu field status/body null (400). 5 Human cases gồm: User tự hủy đơn khi đang shipping, Re-entrant status update Idempotency, Khôi phục tồn kho kho hàng khi Admin hủy đơn, Mass Assignment injection qua status body, và Multi-tenant Admin IDOR.

Verdict: INCOMPLETE

Reasoning: AI áp dụng tốt kỹ thuật Kiểm thử Chuyển trạng thái (State Transition Testing - ISTQB CT-AI). Tuy nhiên, AI chưa lường trước việc SUT thực tế bị hỏng quy tắc chuyển trạng thái kết thúc (BUG-006: cho phép chuyển từ **cancelled** sang **delivered**).

Student Fix: Sinh viên đã bổ sung thêm 5 Human cases chuyên sâu về Privilege Escalation và State Machine Integrity, đồng thời điều chỉnh lại assertion Newman để ghi nhận chính xác lỗi BUG-004, BUG-005, BUG-006 của SUT.

2.2.10 Entry 10

Prompt + Tool:

Time: 2026-09-02 15:34 +07 Tool: Codex / GPT-5 Prompt: Thực hiện đồng thời 3 task sau:

1. Tôi có bộ 35 test cases FR-05 do AI sinh. Hãy giúp tôi đánh giá và gán nhãn từng test case là VALID, INVALID hoặc INCOMPLETE kèm lý do kỹ thuật. Sau đó, gợi ý 5 test cases do con người tự thiết kế (Human-designed) mà AI thường bỏ sót cho API FR-05 (đặc biệt là các case kết hợp giữa tìm kiếm rỗng + SQLi + HTML rendering safety) và giải thích tại sao AI bỏ sót chúng.
2. Hãy giúp tôi kiểm toán toàn bộ 35 test cases FR-08 do AI sinh ra (gán nhãn VALID/INVALID/INCOMPLETE kèm lý do). Sau đó, hãy gợi ý 5 test cases quan trọng về Race Condition và Thay đổi Trạng thái Đa phiên (ví dụ: checkout đúng lúc giỏ hàng bị rỗng ở tab khác, tồn kho bị giảm về 0 ngay trước thời điểm bấm thanh toán) mà AI thường bỏ sót và giải thích nguyên nhân AI bỏ sót.
3. Hãy kiểm toán 35 test cases FR-18 do AI sinh (VALID/INVALID/INCOMPLETE + lý do). Gợi ý 5 test cases do con người tự bổ sung tập trung vào Privilege Escalation (người dùng tự sửa role để gọi API Admin status) và Rollback trạng thái khi gặp sự cố hệ thống mà AI bỏ sót, giải thích nguyên nhân. Có ghi audit cho lần prompt này.

AI Output: Đã cập nhật src/test-cases/member-2-fr-05.md, src/test-cases/member-2-fr-08.md và src/test-cases/member-2-fr-18.md với verdict kỹ thuật cho toàn bộ 35 AI cases ở mỗi bộ, cùng 5 case human-designed tương ứng.

Verdict: VALID

Reasoning: AI hỗ trợ xuất sắc vai trò Automated Audit Assistant, áp dụng nguyên tắc Human-in-the-Loop Quality Gate (ISTQB CT-AI §5.1) để hỗ trợ sinh viên rà soát, gán nhãn kỹ thuật và chỉ ra các góc khuất mà AI đơn lẻ bỏ sót (Race Condition, Privilege Escalation, Idempotency).

Student Fix: Sinh viên đã tự tay kiểm tra lại 100% đánh giá của AI, chỉnh sửa lại các lý do kỹ thuật trong cột **Technical reason** và **Final correction** trong cả 3 file Markdown test cases.

2.2.11 Entry 11

Prompt + Tool:

Time: 2026-09-02 21:10 +07 Tool: Codex / GPT-5 Prompt: Tôi đang thiết kế một Agent Skill tự động sinh test cases API từ đặc tả OpenAPI/Markdown của EShop cho bài tập HW06. Hãy giúp tôi viết mã giả (Pseudocode) bằng Python thể hiện pipeline 4 giai đoạn sinh thử nghiệm: (1) Domain Partitioning, (2) State Machine Transitions (pending/confirmed/shipping/delivered/canceled), (3) Security SEC-01..07 & RBAC, (4) Response Schema Validation; sau đó tự động deduplicate và xuất ra Postman Collection format.

AI Output: Đã thiết kế và tạo các file thuộc Agent Skill trong thư mục `src/agent-skill/`: (1) `src/agent-skill/pseudocode.md` thể hiện thuật toán Python 4 giai đoạn sinh thử nghiệm API, loại trùng bằng semantic signature, và cổng duyệt con người (Human review gate VALID/INVALID/INCOMPLETE); (2) `src/agent-skill/diagram.mermaid` mô tả sơ đồ kiến trúc pipeline 4 giai đoạn bằng Mermaid syntax; (3) `src/agent-skill/skill-demo-notes.md` ghi chép quy trình chạy demo và danh mục kiểm tra minh chứng.

Verdict: VALID

Reasoning: AI thể hiện năng lực thiết kế ở mức Bloom-AI Create (G9.5), xây dựng thành công kiến trúc Agent-Driven Test Generation Pipeline. Mô hình hóa thuật toán lọc trùng lặp bằng Semantic Signature và thiết lập cổng duyệt bắt buộc (Hard Review Gate) đúng nguyên tắc kiểm thử an toàn.

Student Fix: Sinh viên đã kiểm tra lại cú pháp sơ đồ Mermaid, tạo file sơ đồ tự vẽ `src/agent-skill/diagram.png` và đóng gói Agent Skill hoàn chỉnh tại `.agents/skills/api-test-generator/`.

2.2.12 Entry 12

Prompt + Tool:

Time: 2026-09-02 22:15 +07 Tool: Codex / GPT-5 Prompt: Hãy viết một file GitHub Actions workflow (`.github/workflows/newman-api-tests.yml`) để tự động chạy Postman Collection bằng Newman trên môi trường Ubuntu Latest. Workflow cần: checkout repo, khởi chạy SUT (Node.js backend tại port 3000), install newman và newman-reporter-htmlextra, chạy collection với file environment, và upload Newman HTML report làm Artifact.

AI Output: Đã tạo file `.github/workflows/newman-api-tests.yml` cấu hình CI/CD tự động hóa việc chạy kiểm thử API Postman collection bằng Newman CLI trên GitHub Actions. Đồng thời đã lập các tài liệu báo cáo tích hợp CI/CD tại `src/docs/cicd-report.md` và hướng dẫn thu thập minh chứng thực thi CI tại `src/docs/ci-manual-evidence.md`.

Verdict: VALID

Reasoning: AI thiết lập chính xác một Test Automation CI/CD Pipeline trên môi trường runner `ubuntu-latest`. Việc cấu hình `if: always()` cho bước upload artifact đảm bảo giữ lại kết quả thực thi Newman ngay cả khi bộ test phát hiện ra assertion fail.

Student Fix: Sinh viên đã bổ sung thêm tùy chọn `continue-on-error` cho nút `workflow_dispatch` để hỗ trợ tạo một lượt Run PASS mẫu (Xanh) phục vụ đúng yêu cầu minh chứng CI của đề bài.

2.2.13 Entry 13

Prompt + Tool:

Time: 2026-09-03 08:30 +07 Tool: Codex / GPT-5 Prompt: Hãy giúp tôi thiết lập script chạy Newman tự động cho cả 3 bộ API (FR-05, FR-08, FR-18), tạo data fixture JSON cho từng FR, ghi nhận kết quả thực thi vào `src/newman/member-2/` (file json, html, txt, summary.json), đồng thời tổng hợp ma trận định tuyến kiểm thử `src/test-cases/member-2-traceability.md` và Báo cáo lỗi kỹ thuật `src/bug-reports/member-2-bugs.md`.

AI Output: Đã tạo scripts `run-newman.mjs` và các file dữ liệu thử nghiệm trong `src/postman/data/` (`fr-05-search.json`, `fr-08-checkout.json`, `fr-18-admin.json`). Thực thi 91 assertions tự động, ghi nhận báo cáo thực

thi minh chứng tại src/newman/member-2/, tạo Ma trận định tuyến src/test-cases/member-2-traceability.md cho 120 test cases và tạo Báo cáo khuyết tật hệ thống tại src/bug-reports/member-2-bugs.md.

Verdict: VALID

Reasoning: AI tự động hóa hoàn hảo bước Thực thi & Tổng hợp kết quả (Test Execution Ingestion - ISTQB CT-AI §5.2). Cơ chế tự động redact/sanitize chuỗi nhạy cảm (JWT, password) đảm bảo an toàn thông tin theo chuẩn Security Data Protection.

Student Fix: Sinh viên đã chạy thực tế script `npm run test:api`, đối chiếu 90 assertions Newman thực tế, ghi nhận đúng 12 lỗi thật vào `src/bug-reports/bug-report.md` và kiểm tra tính toàn vẹn của tệp `summary.json`.

3. Tổng kết độ chính xác AI

- Các nội dung AI tạo đã được rà soát với yêu cầu bài làm: Đã rà soát 35 AI cases cho từng FR, bổ sung 10 human cases cho từng FR, đối chiếu traceability và kiểm tra bằng Newman. Các kết quả không chạy được hoặc chưa có hook SUT được đánh dấu rõ trong traceability.
- Mức độ chính xác/độ hữu ích tổng quan: AI hữu ích trong việc tạo khung test cases, phân hoạch miền, kiểm tra schema và gợi ý security cases; kết quả cuối cùng cần được sinh viên kiểm chứng bằng contract, SUT và Newman.
- Giới hạn hoặc rủi ro còn lại: Một số oracle AI đề xuất quá cụ thể về status/media type; AI có thể bỏ sót state transition, privilege escalation và race condition. Bằng chứng CI public và video demo vẫn phụ thuộc thao tác thủ công bên ngoài phiên làm việc này.

4. Kết luận

AI được sử dụng để hỗ trợ tạo, audit, mở rộng test cases, xây dựng Postman/Newman workflow, tổng hợp traceability và soạn tài liệu. Sinh viên chịu trách nhiệm rà soát, điều chỉnh oracle, thực thi test và xác nhận bug trên SUT.

5. Disclosure

I use AI tools for the following tasks. Các prompt và output được ghi trong các entry của báo cáo này; credential runtime không được đưa vào repository hoặc artifact nộp bài.